Curated Reading List — Demo-3 Three-Tier Edition

Resilience Engineering, State Management & Data Integrity

DEFCON Coimbatore 2026 · Venugopal Parameswara

> *Demo-2's reading list was about resilience. Demo-3's list adds state: how it gets lost, how it gets preserved, and how it gets corrupted.*

Tier 1 — Read These First (Foundational)

📗 The Phoenix Project

Gene Kim, Kevin Behr, George Spafford | Novel | ~400 pages

- **Why read it:** The B-V-R model exists because of this book. Bill Palmer's team learns that unplanned work and firefighting are the enemy. The "Fourth Way" is MTTR thinking in prose.
- **Best chapter:** When the plant floor goes dark and IT realises they have no recovery playbook. Familiar.
- **Key takeaway:** *"Every improvement made anywhere besides the bottleneck is an illusion."*
- **Difficulty:** ⭐⭐☆☆☆

📘 Site Reliability Engineering (The SRE Book)

Betsy Beyer, Chris Jones, Jennifer Petoff, Niall Murphy (Google) | Free online

- **Why read it:** Google's playbook for building systems that respawn. Chapters on SLOs, error budgets, and incident response map directly to B-V-R.
- **Key chapters:** Ch.13 (Emergency Response), Ch.14 (Managing Incidents), Ch.3 (Risk), Ch.26 (Data Integrity)
- **Free:** https://sre.google/sre-book/table-of-contents/
- **Demo-3 relevance:** Chapter 26 on Data Integrity is the single best short treatment of the tradeoffs Demo-3's DB tier forces you to confront.
- **Difficulty:** ⭐⭐⭐☆☆

📙 Database Reliability Engineering

Laine Campbell, Charity Majors | O'Reilly | ~290 pages

- **Why read it:** Demo-3 claims DB MTTR is ~12 seconds. This book explains why that's hard, what it costs, and how to actually measure it under load. Replication lag, WAL shipping, PITR — all treated as first-class SRE concerns.
- **Key chapters:** Ch.5 (Infrastructure Engineering), Ch.8 (Release Management), Ch.10 (Data Warehousing — counterpoint)
- **Demo-3 relevance:** This is the single book most aligned with Demo-3's DB tier story. If you only read one new book from this list, make it this one.
- **Difficulty:** ⭐⭐⭐⭐☆

📘 Chaos Engineering

Casey Rosenthal & Nora Jones (Netflix) | O'Reilly | ~280 pages

- **Why read it:** The scientific foundation for GameDays. Netflix's Chaos Monkey and the discipline of breaking production on purpose.
- **Key chapter:** Ch.2 — What Chaos Engineering is NOT
- **Key takeaway:** *"Chaos Engineering is the discipline of experimenting on a system to build confidence in its capability to withstand turbulent conditions in production."*
- **Difficulty:** ⭐⭐⭐☆☆

Tier 2 — Go Deeper (Intermediate)

📕 Designing Data-Intensive Applications

Martin Kleppmann | O'Reilly | ~600 pages

- **Why read it:** The canonical text on how replicated data systems actually work. Every decision Demo-3's DB tier makes — synchronous commit, WAL streaming, single-leader replication — is catalogued here with tradeoffs.
- **Key chapters:** Ch.5 (Replication), Ch.7 (Transactions), Ch.9 (Consistency and Consensus)
- **Demo-3 relevance:** Chapter 5 directly explains why `pg_wal_replay_pause` is a legitimate defence primitive and not a hack.
- **Difficulty:** ⭐⭐⭐⭐☆

📗 The Unicorn Project

Gene Kim | Novel | ~350 pages

- **Why read it:** Sequel to Phoenix Project. Maxine's "Five Ideals" map to immutable infrastructure and B-V-R.

- **Demo-3 relevance:** Ideal 3 (Improvement of Daily Work) is guardian.sh in prose form.
- **Difficulty:** ⭐⭐☆☆☆

📘 Accelerate — The Science of Lean Software and DevOps

Nicole Forsgren, Jez Humble, Gene Kim | ~288 pages

- **Why read it:** Data-backed proof that MTTR and deployment frequency — not change failure rate — are the leading indicators of organisational performance. DORA metrics = B-V-R in enterprise language.
- **Key finding:** Elite performers have MTTR < 1 hour. Most companies: days to weeks.
- **Difficulty:** ⭐⭐⭐☆☆

📙 Container Security

Liz Rice | O'Reilly | ~250 pages

- **Why read it:** Demo-3 runs five containers. This book explains exactly what isolation containers provide (and don't) — namespaces, cgroups, seccomp, the real story.
- **Key chapter:** Ch.9 — Breaking Container Isolation
- **Free online preview:** https://containersecurity.tech
- **Difficulty:** ⭐⭐⭐☆☆

📕 PostgreSQL: Up and Running (3rd Ed.)

Regina Obe, Leo Hsu | O'Reilly | ~320 pages

- **Why read it:** Demo-3's DB tier uses streaming replication, `pg_stat_replication`, `pg_wal_replay_pause` — all first-class Postgres primitives. This book treats them as the everyday tools they are.
- **Key chapters:** Ch.2 (Server Administration), Ch.4 (Replication)
- **Difficulty:** ⭐⭐⭐☆☆

📘 Hacking — The Art of Exploitation (2nd Ed.)

Jon Erickson | No Starch Press | ~488 pages

- **Why read it:** To understand V, you need to understand how attacks work at the code level. Buffer overflows, shellcode, network exploitation.
- **Relevance to Demo-3:** Shows why V can be measured in seconds. Complements the WAF-focused reading below.
- **Difficulty:** ⭐⭐⭐⭐☆

📕 Web Application Security (2nd Ed.)

Andrew Hoffman | O'Reilly | ~330 pages

- **Why read it:** Demo-3's WAF tier fires real ModSecurity CRS rules. This book maps each OWASP Top 10 to the detection primitives and explains where CRS helps vs where application code has to carry the weight.
- **Demo-3 relevance:** Chapter 14 (XSS Defense) and Chapter 15 (SQLi Defense) explain exactly the categories Wave 2 and Wave 3 of `attack3_waf.sh` exercise.
- **Difficulty:** ⭐⭐⭐☆☆

Tier 3 — Reference Material

📋 NIST SP 800-61r3 — Computer Security Incident Handling Guide

NIST | Free PDF

- **Why read it:** The US government framework for incident response. Maps directly to R (Recovery Runway): detection, containment, eradication, recovery.
- **Free:** https://doi.org/10.6028/NIST.SP.800-61r3
- **Use it as:** A checklist, not bedtime reading.

📋 NIST SP 800-184 — Guide for Cybersecurity Event Recovery

NIST | Free PDF

- **Why read it:** 800-61 is about IR process; 800-184 is about *recovery* specifically — exactly the R in B-V-R. Two appendices cover data integrity recovery which is directly relevant to Demo-3's DB fence path.
- **Free:** https://csrc.nist.gov/pubs/sp/800/184/final

📋 MITRE ATT&CK Framework

MITRE | Free online

- **Why read it:** The definitive taxonomy of attacker techniques.
- **Containers matrix:** https://attack.mitre.org/matrices/enterprise/containers/
- **For Demo-3 cross-reference:** T1485, T1486, T1190, T1548, T1552.001, T1059.007, T1083, T1595.002

📋 OWASP ModSecurity Core Rule Set (CRS) Documentation

OWASP | Free online

- **Why read it:** The exact rules that produce Demo-3's 13 real 403 responses. Includes paranoia levels and rule-tuning guidance.
- **Free:** https://coreruleset.org
- **Demo-3 relevance:** `attack3_waf.sh` triggers rules 942100+, 941100+, 930100+ — trace each block back to its rule.

📋 PostgreSQL 15 Documentation — High Availability

PostgreSQL | Free online

- **Why read it:** Demo-3's `pg_wal_replay_pause`, `pg_stat_replication`, and `pg_ctl promote` all live in this section of the docs.
- **Free:** https://www.postgresql.org/docs/15/high-availability.html
- **Start with:** § 27.2 (Log-Shipping Standby Servers), § 27.4 (Hot Standby)

📋 Patroni Documentation

Zalando / Community | Free online

- **Why read it:** CTF Level 3 asks you to make `pg_ctl promote` automatic. Patroni is the productionised version of that answer.
- **Free:** https://patroni.readthedocs.io

📋 CIS Docker Benchmark

Center for Internet Security | Free PDF

- **Why read it:** Demo-3's Dockerfiles have intentional gaps. This benchmark tells you how to harden them for production.
- **Free:** https://www.cisecurity.org/benchmark/docker

📋 SLSA — Supply-chain Levels for Software Artifacts

Google / Open Source Security Foundation | Free online

- **Why read it:** CTF Level 4 asks about supply-chain attacks. SLSA is the framework you'll reference in the answer.
- **Free:** https://slsa.dev

📋 sigstore / cosign Documentation

Linux Foundation | Free online

- **Why read it:** Production golden-image signing. The missing piece between Demo-3's `:golden` tag and a production image-trust story.
- **Free:** https://docs.sigstore.dev

Online Courses & Labs

Resource	Platform	Focus	Free?
TryHackMe — SOC Level 1	TryHackMe	Detection & response	Partial
HackTheBox — DevSecOps	HackTheBox	Container security	Partial
Google SRE Course	Coursera	Reliability engineering	Audit free
Chaos Engineering Fundamentals	Gremlin Academy	GameDays	Free
KodeKloud — Container Security	KodeKloud	Docker/K8s hardening	Partial
OWASP WebGoat	Self-hosted	App vulnerabilities	Free
ModSecurity CRS Rule Lab	Self-hosted	WAF rule tuning	Free
Postgres Playground — Replication Setup	Self-hosted	WAL streaming hands-on	Free

---

YouTube / Talks Worth Watching

Talk	Speaker	Where
"Chaos Engineering at Netflix"	Casey Rosenthal	QCon 2015
"SRE at Google"	Ben Treynor Sloss	SREcon
"Container Security Deep Dive"	Liz Rice	KubeCon
"MITRE ATT&CK for Containers"	Ian Coldwater	DEFCON
"How Complex Systems Fail"	Richard Cook	Velocity
"Designing for Disaster"	Tammy Bryant	QCon London
"Postgres Replication — The Good, The Bad, The Ugly"	Magnus Hagander	PgCon
"ModSecurity in Depth"	Christian Folini	OWASP AppSecEU

The B-V-R Reading Order (Demo-3 Edition)

If you only have time for four things:

```
Week 1:  The Phoenix Project (novel — just read it)
Week 2:  SRE Book Ch. 3, 13, 14, 26 (free online)
Week 3:  Database Reliability Engineering Ch. 5–8
Week 4:  Run Demo-3 yourself + complete CTF Levels 1–2
```

That's the curriculum. The rest is depth.

The Next-Step Question

After reading the above, you should be able to answer these without looking things up:

1. What is the default `wal_level` on Postgres 15, and why does Demo-3 change it to `replica`?
2. What's the difference between `pg_wal_replay_pause` and stopping the replica?
3. Why does CRS paranoia level 1 let some borderline payloads through?
4. What's the relationship between `docker kill`, `docker stop`, and `docker rm -f`?
5. Why doesn't Kubernetes solve Demo-3's DB tier problem out of the box?

If you can't answer those, go back and pick whichever book from Tier 1–2 covers the gap.

DEFCON Coimbatore 2026 · Demo-3 · Venugopal Parameswara · CISO & Cyber Strategist